

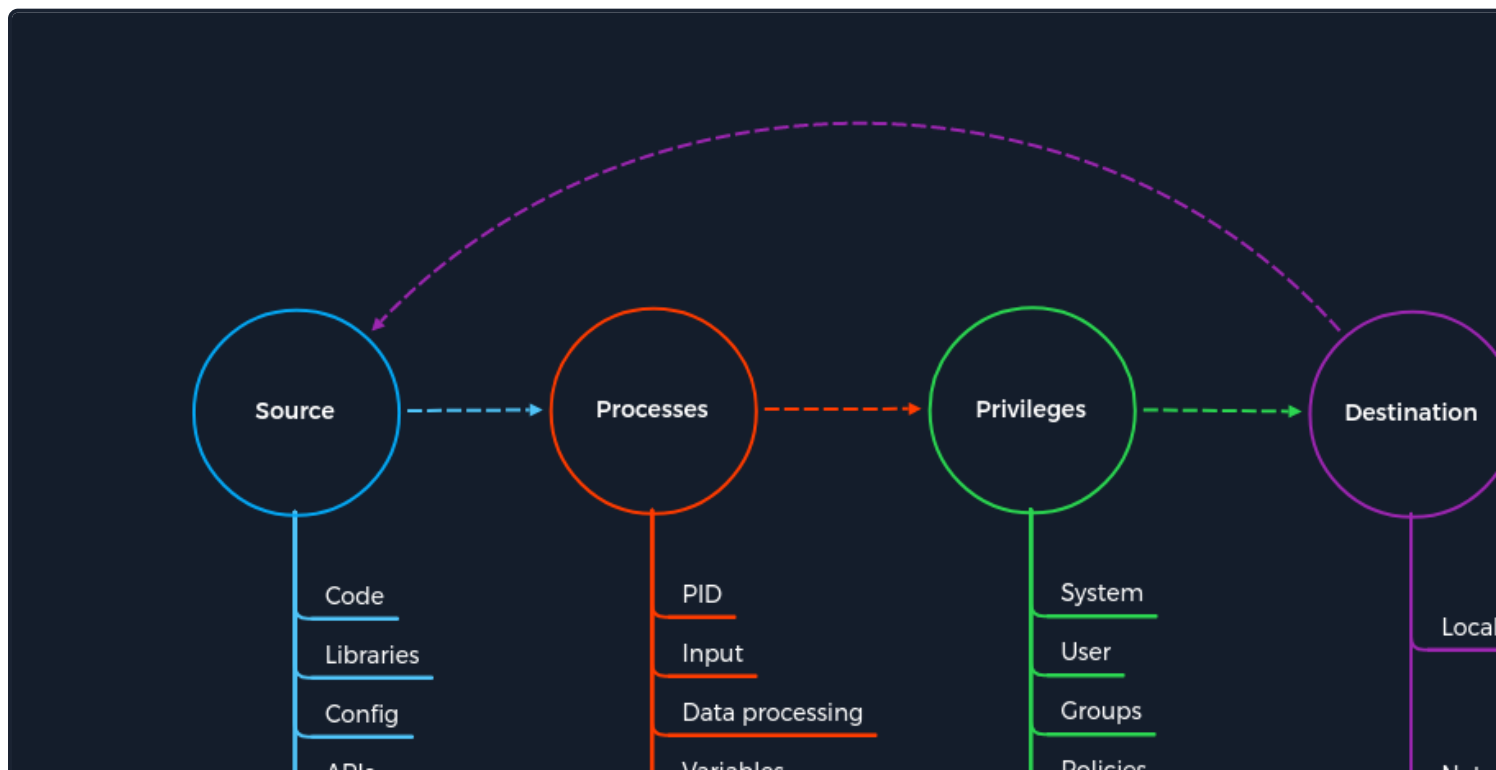
Latest RDP Vulnerabilities

In 2019, a critical vulnerability was published in the RDP (TCP/3389) service that also led to remote code execution. This vulnerability is known as **BlueKeep**. It does not require prior access to the system to be exploited for malicious purposes. However, the exploitation of this vulnerability led and still leads to many malware or ransomware attacks. Systems such as hospitals, whose software is only designed for specific versions and libraries, are particularly vulnerable. Since infrastructure maintenance is costly. Here, too, we will not go into minute detail about this vulnerability but only about the basic concept.

The Concept of the Attack

The vulnerability is also based, as with SMB, on manipulated requests sent to the targeted service. However, unlike SMB, that the vulnerability does not require user authentication to be triggered. Instead, the vulnerability occurs when basic settings are exchanged between client and server. This is known as a **Use-After-Free (UAF)** technique, which allows the attacker to execute arbitrary code.

The Concept of Attacks



2. The request leads to a function used to create a virtual channel containing the vulnerability.
3. Since this service is suitable for [administering](#) of the system, it is automatically run with the [LocalSystem Account](#) privileges of the system.
4. The manipulation of the function redirects us to a kernel process.

This is when the cycle starts all over again, but this time to gain remote access to the target system.

Trigger Remote Code Execution

Step BlueKeep

5. The source this time is the payload created by the attacker that is inserted into the process to free the memory in the kernel and place our instructions.
6. The process in the kernel is triggered to free the kernel memory and let the CPU point to our code.
7. Since the kernel also runs with the highest possible privileges, the instructions we put into the freed kernel memory here are also executed with [LocalSystem Account](#) privileges.
8. With the execution of our instructions from the kernel, a reverse shell is sent over the network to our host.

Not all newer Windows variants are vulnerable to Bluekeep, according to Microsoft. Security updates for Windows 10 are available, and Microsoft has also provided updates for many older Windows versions that are no longer supported. In an initial scan in May 2019, and even today, those hosts are still vulnerable.

Note: This is a flaw that we will likely run into during our penetration tests, but it can cause system crashes, a "blue screen of death (BSOD)," and we should be careful before using the associated exploit. If in doubt, it's best to inform the client so they understand the risks and then decide if they would like us to run the exploit or not.

[< Previous](#)[Next >](#)

+10 Strea

[Cheat Sheet](#)[Resources](#)

 Attacking SMB

Latest SMB Vulnerabilities

SQL Databases

 Attacking SQL Databases

Latest SQL Vulnerabilities

RDP

 Attacking RDP

[Latest RDP Vulnerabilities](#)

DNS

 Attacking DNS

Latest DNS Vulnerabilities

SMTP

 Attacking Email Services

Latest Email Service Vulnerabilities

Skills Assessment

 Attacking Common Services - Easy Attacking Common Services - Medium Attacking Common Services - Hard

My Workstation

O F F L I N E

 Start Instance